

Coruna is a sophisticated iOS exploit kit publicly disclosed on March 3, 2026. The kit, internally named "Coruna" by its developers, contains five complete exploit chains and 23 individual exploits targeting Apple iPhone models running iOS versions 13.0 through 17.2.1. It is the first documented case of a nation-state-grade iOS exploit framework proliferating from a commercial surveillance vendor into the hands of financially motivated cybercriminals.

In 2025, Coruna was observed by Google's and iVerify's researchers in at least three distinct campaigns: first by an unnamed customer of a surveillance company, then in watering-hole attacks against Ukrainian targets attributed to UNC6353 (a suspected Russian espionage group), and finally in broad-scale cryptocurrency theft operations by UNC6691, a financially motivated threat actor based in China. Kaspersky's Global Research and Analysis Team (GReAT) subsequently confirmed that two exploits within the kit (internally codenamed Photon and Gallium) target the same vulnerabilities exploited as zero-days in Operation Triangulation, a campaign discovered in 2023 targeting iPhones in Russia.

iVerify, which independently tracked the kit under the name CryptoWaters, assessed that Coruna shared structural similarities with frameworks previously attributed to threat actors affiliated with the United States government.

The exploit kit is not effective against the latest versions of iOS. Apple issued security advisories and backported patches for older iOS versions in response to the disclosure. The U.S. Cybersecurity and Infrastructure Security Agency (CISA) added three Coruna-related vulnerabilities to its Known Exploited Vulnerabilities catalog on March 5, 2026.

Background

Before Coruna, the most prominent example of offensive cybertool proliferation was EternalBlue, a Microsoft Windows exploit allegedly developed by the U.S. National Security Agency (NSA). It was leaked by the Shadow Brokers in 2017 and then used in the WannaCry and NotPetya ransomware attacks. iVerify explicitly drew parallels between the two cases.

Operation Triangulation, discovered by Kaspersky in 2023, was a separate advanced persistent threat (APT) campaign. It deployed zero-click exploits against iPhones via iMessage. Kaspersky researchers presented their findings at the 37th Chaos Communication Congress (37C3). The Russian government alleged at the time that the campaign was conducted by U.S. intelligence, a claim neither confirmed nor denied by American officials.

Discovery and disclosure

Initial discovery

In February 2025, Google TIG captured parts of an iOS exploit chain being used by a customer of an unnamed commercial surveillance company. The exploits were embedded within a previously unseen JavaScript framework that employed distinctive obfuscation techniques. The framework began by fingerprinting the target device to determine iPhone model and iOS version before delivering the appropriate WebKit remote code execution exploit, followed by a pointer authentication code (PAC) bypass. At this stage, GTIG recovered the WebKit RCE targeting iOS 17.2, which was identified as CVE-2024-23222, a type-confusion vulnerability Apple had patched in January 2024 with iOS 17.3.

Watering-hole attacks in Ukraine

In mid-2025, GTIG detected the same JavaScript framework, which was loaded as a hidden iframe on numerous compromised Ukrainian websites spanning sectors including industrial equipment, retail, local services, and e-commerce. The framework was only delivered to selected iPhone users from a specific geolocation. GTIG collected additional WebKit RCE exploits (CVE-2022-48503 and CVE-2023-43000) before the server was taken down. The activity was attributed to UNC6353, a suspected Russian espionage group. GTIG coordinated with CERT-UA to remediate the compromised sites.

Chinese cybercrime campaigns

By late 2025, GTIG identified the JavaScript framework deployed across a large network of fraudulent Chinese websites, primarily related to finance and cryptocurrency. These included fake versions of crypto exchanges such as WEEX, which displayed pop-ups urging visitors to access the sites from an iPhone or iPad. Upon visiting from an iOS device, a hidden iframe injected the Coruna exploit kit regardless of the visitor's geographic location.

This campaign was attributed to UNC6691, a financially motivated Chinese threat actor. An operational error by the attackers (deploying a debug version of the exploit kit with unobfuscated code) enabled researchers to recover the full set of exploits along with their internal codenames, and to confirm the internal name "Coruna". iVerify independently discovered the same campaign and tracked it under the designation CryptoWaters.

Public disclosure

GTIG and iVerify published their findings simultaneously on March 3, 2026. The reports were first covered by Wired. On March 5, 2026, CISA added CVE-2021-30952, CVE-2023-41974, and CVE-2023-43000 to its Known Exploited Vulnerabilities catalog with a remediation deadline of March 26, 2026, for federal agencies. Kaspersky GReAT published a complementary analysis on March 26, 2026, confirming the kernel exploit targeting CVE-2023-32434 and CVE-2023-38606 was an updated version of the exploit used in Operation Triangulation.

Technical description

Architecture and delivery

Coruna is delivered as a self-contained HTML file, typically named group.html or analytics.html, embedded as a hidden zero-dimension iframe within a web page. The exploit runs entirely in the browser via JavaScript and requires no user interaction beyond loading the page. The framework first performs device fingerprinting to identify the target's iPhone model

and iOS version. It will abort execution if the device is in Lockdown Mode or the user is using private browsing.

After fingerprinting, the framework selects and delivers the appropriate WebKit RCE exploit, followed by a PAC bypass. A unique hard-coded cookie is used to generate resource URLs. Post-exploitation binary payloads are served from URLs ending in .min.js, encrypted and compressed.

Exploit inventory

The kit contains 23 exploits organized into five full chains that cover iOS 13.0 through 17.2.1. These are divided into several categories: WebKit RCE exploits (codenamed Buffout, Jacurutu, Bluebird, Terrorbird, and Cassowary), PAC bypasses (Breezy and Seedbell variants), WebContent sandbox escapes (IronLoader and NeuronLoader), kernel privilege escalation exploits (Neutron, Pendulum, Photon, Parallax, and Gruber), and PPL bypasses (Quark, Gallium, Carbone, Sparrow, and Rocket). The exploits include extensive documentation with comments authored in native English.

Notable are Photon and Gallium exploits (exploiting CVE-2023-32434 and CVE-2023-38606), which target the same vulnerabilities used as zero-days in Operation Triangulation. Kaspersky's analysis determined that the Coruna kernel exploit for these vulnerabilities is an updated version of the same exploit used in the earlier campaign, with added support for newer Apple processors (A17, M3 series) and checks for iOS 17.2. The kit also includes reusable modules to bypass mitigations preventing allocation of read-write-execute memory pages.

Malicious payload

The ending payload in the Chinese campaign consisted of a stager binary called PlasmaLoader, tracked by GTIG as PLASMAGRID, which uses the identifier com.apple.assistd.

The loader injects itself into powerd, a daemon running as root on iOS. The payload is focused on financial theft: it could decode QR codes from device images, scan Apple Memos for BIP-39 seed phrases and keywords such as "backup phrase" or "bank account", and deploy additional modules targeting cryptocurrency wallet applications.

Targeted wallet applications included MetaMask, Phantom, Exodus, and over a dozen others. Each module functioned by placing function hooks within the targeted app to exfiltrate wallet credentials and seed phrases. The modules contained logging strings written in Chinese, some of which appeared to be generated by a large language model based on their style and use of emojis.

Network communication used HTTPS with data encrypted via AES. The implant contained hard-coded command-and-control domains with a fallback domain generation algorithm using the seed string "lazarus" to produce predictable 15-character domains with a .xyz top-level domain. iVerify additionally recovered modules targeting iMessage (imagent) and WhatsApp that were not present in the samples analyzed by Google.

Attribution and origins

The origin of Coruna and the mechanism by which it changed hands between different threat actors is unknown. GTIG framed the proliferation as evidence of an active secondary market for exploit tools, without attributing the kit's creation to a specific entity.

iVerify went further, highlighting structural similarities of the exploit kit with frameworks previously developed by threat actors affiliated with the U.S. government. iVerify's co-founder Rocky Cole stated that the company believed the framework had such links. The company compared the situation to EternalBlue, noting that this is the first observed mass exploitation of iOS devices by a criminal group using tools likely built by a nation-state.

Kaspersky confirmed that the Coruna kernel exploit is an updated version of the same codebase used in Operation Triangulation, built on a common exploitation framework with

shared code across multiple components.

Media speculation has linked Coruna to the case of Peter Williams, a former general manager of Trenchant, an L3Harris division that develops zero-day exploits for the U.S. government and Five Eyes allies. Williams was sentenced in February 2026 to 87 months in federal prison for stealing eight exploit components from Trenchant between 2022 and 2025 and selling them to Operation Zero, a Russian exploit broker, in exchange for \$1.3 million in cryptocurrency. The U.S. Treasury confirmed that Operation Zero subsequently sold the stolen tools to at least one unauthorized user. The nature of the specific exploits Williams sold has not been publicly disclosed.

Impact

iVerify estimated that at least 42,000 iPhones may have been compromised in the Chinese cybercrime wave alone, making it the first known mass exploitation campaign against iOS devices.

Apple response

Apple issued a support document urging users on older iOS versions to update, noting that fully updated devices were not affected. The company backported patches for Coruna-related vulnerabilities to iOS 15.8.7, iOS 16.7.15, and related iPadOS versions on March 11, 2026, extending protection to devices that could not run iOS 17 or later. For devices still on iOS 13 or 14, Apple advised upgrading to iOS 15 and promised that a Critical Security Update would follow. Apple also noted that Lockdown Mode and Safari's Safe Browsing feature provide additional protection.

Government response

CISA added CVE-2021-30952, CVE-2023-41974, and CVE-2023-43000 to its Known Exploited

Vulnerabilities (KEV) catalog on March 5, 2026, with a mandatory remediation deadline of March 26, 2026, for federal civilian agencies.

Relation to DarkSword

A few weeks after Coruna's disclosure, iVerify reported a second exploit kit called DarkSword targeting newer iOS versions (18.4–18.7) and also deployed in watering-hole attacks against Ukrainian targets by UNC6353. DarkSword exploited several zero-day vulnerabilities and appeared to share lineage with Coruna's exploit infrastructure. Apple's security advisories addressed both kits.

Significance

Cybersecurity analysts describe Coruna as a landmark case in the proliferation of offensive cyber capabilities. The kit's migration from a surveillance vendor's customer to a state-backed espionage group and then to cybercriminals conducting mass-scale financial theft illustrated the dangers of a secondary market in exploit tools. The EternalBlue leak has already demonstrated this pattern for desktop operating systems. Coruna was the first to demonstrate it at scale for mobile devices.

This case brought back an old argument: should governments keep software flaws a secret to use for hacking, or should they report them to tech companies so they can be fixed? As iVerify noted, when such tools enter secondary markets, it becomes nearly impossible to control who uses them and for what purposes.

See also

Operation Triangulation

EternalBlue

Pegasus (spyware)

NSO Group

Spyware

== References ==